Quick Consultant

Preparado para esentia RECURSOS HUMANOS

ESTRATEGIA DE SEGURIDAD DE LA INFORMACIÓN

# Cómo cuidamos la información del Concurso Bancor

Qué datos protegemos, dónde se guardan, quién puede verlos y qué hacemos frente a los ataques más comunes. Escrito para que se entienda sin conocimientos técnicos.

Plataforma de gestión de búsquedas | Versión 1 · Noviembre 2026 | Confidencial

EN UNA PÁGINA

## Seis compromisos

La información del concurso incluye datos personales de miles de postulantes de una entidad bancaria. La tratamos como información de máxima confidencialidad.

1

### Guardamos lo mínimo

Solo los datos necesarios para el concurso. Nada de informes médicos ni financieros completos.

2

### Cada persona ve solo lo suyo

Usuarios personales con tres niveles de acceso: Admin, Operador y Externo.

3

### Doble llave para entrar

Contraseña más un código en el celular, obligatorio para todos.

4

### Todo queda registrado

Cada acción queda anotada con nombre, fecha y hora, y nadie puede borrar ese registro.

5

### Información siempre cifrada

Ilegible para quien no tenga permiso, tanto guardada como mientras viaja por internet.

6

### Plan si algo falla

Copias de seguridad diarias y un procedimiento claro para actuar en minutos ante un incidente.

01 · QUÉ CUIDAMOS

# La información y su nivel de sensibilidad

| INFORMACIÓN | NIVEL | QUÉ HACEMOS |
|---|---|---|
| **Contraseñas y claves de acceso** | Crítica | No las guardamos nosotros: las administra un servicio especializado y nadie, ni siquiera nuestro equipo, puede verlas. |
| **Preocupacional** (dato de salud) | Crítica | Solo registramos “Apto / No apto”. El detalle médico nunca entra a la plataforma. |
| **Antecedentes** (Nosis, referencias) | Muy alta | Solo el resultado (favorable o desfavorable y su puntaje), no el informe completo. |
| **Datos personales** (DNI, contacto, fecha de nacimiento, estudios, experiencia) | Muy alta | Guardados cifrados. Solo los ven el equipo de ESENTIA con rol Admin u Operador. |
| **Resultados y orden de mérito** | Alta | Definen quién ingresa al Banco: todo cambio exige un motivo escrito y queda registrado. |

02 · DÓNDE VIVE LA INFORMACIÓN

# Tecnologías y servidores

La plataforma funciona “en la nube”: en lugar de una computadora en una oficina, usa centros de datos profesionales con vigilancia, energía de respaldo y certificaciones internacionales de seguridad.



Recorrido de la información: el usuario entra con su doble llave, la aplicación verifica qué puede ver y recién entonces busca los datos en la base cifrada.

| SERVICIO | PARA QUÉ LO USAMOS | DÓNDE ESTÁ | CERTIFICACIONES DEL PROVEEDOR |
|---|---|---|---|
| **Supabase** | Base de datos (PostgreSQL), inicio de sesión y archivos de las cargas. | Centro de datos de Amazon Web Services en São Paulo, Brasil. | SOC 2 Tipo II. |
| **Amazon Web Services** | Infraestructura física sobre la que funciona Supabase. | São Paulo, Brasil. | ISO 27001, SOC 1, 2 y 3, PCI DSS. |
| **Netlify** | Publica la aplicación web y la protege de picos de tráfico. | Red global de servidores. | SOC 2 Tipo II. |
| **GitHub** | Guarda el código de la plataforma en un repositorio privado. No contiene datos de postulantes. | Estados Unidos. | SOC 1 y SOC 2. |
| **Correo transaccional** (por ejemplo, Resend) | Envía invitaciones y avisos de seguridad desde un dominio verificado. | Estados Unidos. | SOC 2 Tipo II. |
| **Cloudflare Turnstile** | Verificación en el inicio de sesión para frenar robots. | Red global. | ISO 27001, SOC 2. |

Certificaciones según lo publicado por cada proveedor. Los informes se pueden solicitar a cada uno bajo acuerdo de confidencialidad.

**Tecnologías de la aplicación:** Next.js y React (pantallas), TypeScript (código con controles de tipos), PostgreSQL (base de datos), Prisma (consultas seguras a la base), Supabase Auth (inicio de sesión con doble llave) y reglas de acceso por fila en la base de datos. Todo es tecnología ampliamente usada en el mundo y con actualizaciones de seguridad permanentes.

03 · FRENTE A LOS ATAQUES

# Qué hacemos ante cada amenaza

Estos son los ataques más frecuentes contra plataformas como esta y la protección que tiene cada uno.

### 🎣 Robo de contraseñas

Un email falso que imita a ESENTIA o al Banco y pide la clave. Es el ataque más común.

- Sin el código del celular, la contraseña sola no alcanza.
- Se rechazan contraseñas débiles o ya filtradas en internet.
- Aviso por email ante cada ingreso desde un equipo nuevo.

### 🔁 Adivinar contraseñas

Programas que prueban miles de combinaciones por minuto.

- Bloqueo del usuario después de 5 intentos fallidos.
- Verificación anti-robots en el inicio de sesión.
- La sesión se cierra sola a los 30 minutos sin uso.

### 🚪 Ver datos sin permiso

Alguien con usuario válido intenta ver postulantes o datos que no le corresponden.

- La base de datos solo entrega lo que cada rol puede ver.
- Pruebas automáticas que lo verifican en cada versión.
- Cada consulta queda en el registro.

### 🏢 Proveedor externo hackeado

Le roban el usuario a alguien de la UNC o de una consultora.

- Solo vería DNI, nombre, vacante y localidad de una etapa.
- Sus cargas no impactan sin la revisión de ESENTIA.
- El acceso vence solo al cerrar la etapa.

### 🕵️ Fuga desde adentro

Alguien con acceso legítimo intenta llevarse la base.

- Cada uno tiene solo el acceso que necesita.
- Las exportaciones quedan marcadas con nombre y fecha.
- Alerta ante descargas masivas o fuera de horario.

### 📎 Archivos con virus

Un Excel preparado para dañar el sistema o a quien lo abra.

- Solo se aceptan Excel y CSV, con tamaño máximo.
- Se leen sin ejecutar macros ni fórmulas.
- Los Excel que exportamos salen sin fórmulas activas.

### 🔐 Secuestro de datos (ransomware)

Un atacante bloquea o borra la información y pide rescate.

- Copia de seguridad diaria y una semanal guardada aparte.
- Restauración a un momento anterior sin pagar nada.
- Nada se borra en forma definitiva: todo cambio se puede revertir.

### 🌐 Ataque a los servidores

Intentos de entrar a la infraestructura o de saturar el sitio para dejarlo fuera de servicio.

- Doble llave en todas nuestras cuentas de administración.
- Las claves maestras nunca salen del servidor.
- La red de Netlify absorbe los picos de tráfico.

### 🧩 Software contaminado

Una pieza de código de terceros con fallas o intenciones maliciosas.

- Usamos pocas piezas externas, todas de uso masivo.
- Alertas automáticas cuando alguna tiene una falla conocida.
- Cada actualización se revisa antes de publicarla.

### 📞 Engaño telefónico o por email

Alguien se hace pasar por el Banco para pedir la base de postulantes.

- Las exportaciones al Banco se piden solo por un canal formal acordado.
- Se verifica a quien pide antes de entregar.
- Nuestros emails salen de un dominio verificado, difícil de imitar.

04 · SI ALGO PASA

## Plan de respuesta ante incidentes

PASO 1

**Detectar**

Alertas automáticas por ingresos extraños, descargas masivas o intentos de acceso indebido.

**Al instante**

PASO 2

**Contener**

Cerramos todas las sesiones, bloqueamos usuarios, cambiamos claves y pausamos accesos externos.

**En minutos**

PASO 3

**Avisar**

Informamos a ESENTIA y a Bancor qué pasó y qué se hizo, para que el Banco cumpla sus obligaciones ante el BCRA.

**Dentro de las 24 horas**

PASO 4

**Analizar y corregir**

Con el registro de actividad sabemos qué se vio, quién y cuándo. Corregimos la causa y entregamos un informe.

**Informe en 5 días hábiles**

El plan queda por escrito y se ensaya una vez antes de empezar a operar con datos reales.

05 · NORMATIVA

# Marco legal y contractual

| | |
|---|---|
| **Ley 25.326**<br>Protección de Datos Personales | ESENTIA (o el Banco) es el responsable de la base y la inscribe ante la Agencia de Acceso a la Información Pública. Quick Consultant actúa como **encargado del tratamiento**: trata los datos solo para este concurso y por contrato. |
| **BCRA · Comunicación A 7724** | Establece los requisitos de seguridad de la información y de gestión de proveedores tecnológicos para las entidades financieras. Esta estrategia está pensada para responder el cuestionario de seguridad que Bancor pueda solicitar. |
| **Confidencialidad** | Acuerdo de confidencialidad firmado por todas las personas con acceso, incluidos los proveedores externos. |
| **Fin del concurso** | Entregamos la base completa a ESENTIA, la eliminamos de la plataforma y de las copias de seguridad en el plazo acordado, y dejamos constancia escrita. |

06 · CÓMO LO VERIFICAMOS

# Controles antes y durante el concurso

- ✓ Revisión de la plataforma contra la lista de controles OWASP ASVS nivel 2, un estándar internacional para aplicaciones web.
- ✓ Pruebas automáticas de permisos: cada nivel de acceso se verifica en cada versión nueva.
- ✓ Prueba de recuperación: restauramos una copia de seguridad completa antes de salir a producción.
- ✓ Revisión mensual de usuarios activos junto con ESENTIA.
- ✓ Recomendamos una prueba de intrusión realizada por una empresa independiente antes de operar con datos reales.

07 · PARA DEFINIR

# Decisiones pendientes

- ? ¿Bancor acepta que los datos se guarden en São Paulo, Brasil, o exige otra ubicación?
- ? ¿Bancor va a solicitar un cuestionario de seguridad o una prueba de intrusión independiente?
- ? ¿En qué plazo se eliminan los datos al cerrar el concurso? Sugerimos 90 días.
- ? ¿Quién firma por ESENTIA como responsable de la base de datos?

GLOSARIO

# Palabras técnicas, en simple

**Doble llave (segundo factor)**
Además de la contraseña, un código que cambia cada 30 segundos en una aplicación del celular.

**Copia de seguridad**
Una copia completa de la información para recuperarla si algo se pierde o se daña.

**Prueba de intrusión**
Una empresa especialista intenta atacar la plataforma, con permiso, para encontrar puntos débiles antes que un atacante real.

**Cifrado**
Convertir la información en un código ilegible que solo se puede leer con la clave correcta.

**Phishing**
Engaño por email o mensaje que imita a alguien conocido para robar contraseñas.

**SOC 2 e ISO 27001**
Certificaciones internacionales que acreditan que un proveedor tiene controles de seguridad auditados.

**HTTPS**
El candado del navegador: la información viaja cifrada entre la computadora y el servidor.

**Ransomware**
Ataque que bloquea la información y pide un pago para liberarla.

**Registro de actividad**
Un historial de todo lo que pasa en la plataforma: quién, qué y cuándo. No se puede modificar.

RESUMEN

**Guardamos solo los datos necesarios, cifrados y en centros de datos certificados. Cada persona entra con doble llave, ve solo lo que su rol permite y todo queda registrado. Ante un incidente actuamos en minutos, con copias diarias y aviso a ESENTIA y Bancor en 24 horas.**

La propuesta y esquema de solución son confidenciales, prohibida su distribución con terceros.
Todos los derechos reservados por Quick Consultant. – Córdoba 2026